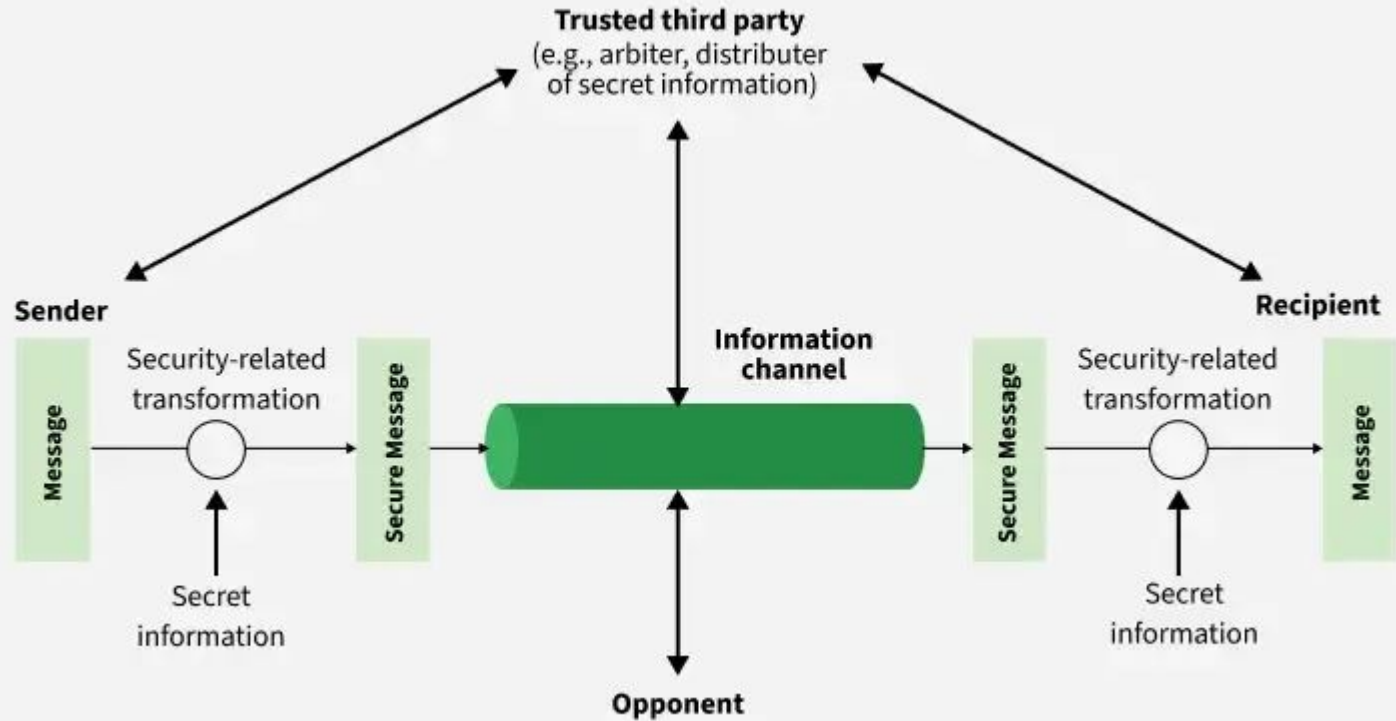


Network Security

Er. Sudarshan Devkota

Model for Network Security



Model for Network Security

The fundamental goal of a Network Security Model is to establish a secure framework that protects data as it traverses a network.

In any communication environment, an "opponent" a hostile entity or malicious actor may attempt to intercept, read, or modify information.

Any security service would have the three components:

1. Transformation
2. Sharing Secret Information
3. Trusted Third Party

Model for Network Security

1. Transformation:

The original message (plaintext) is transformed into an unreadable format (ciphertext).

This ensures that even if an opponent intercepts the data on the transmission channel, they cannot extract the actual information without the corresponding decryption mechanism.

Beyond simple scrambling, the transformation process often includes the addition of specific cryptographic codes or signatures.

These codes allow the receiver to verify the identity of the sender and confirm that the message has not been altered or tampered with during transit.

Model for Network Security

2. Sharing Secret Information:

Transformation alone is insufficient if the "rules" of that transformation are known by the opponent.

This brings us to the second component: the sharing of secret information, commonly known as cryptographic keys.

The key acts as the variable input for the encryption algorithm. Even if an opponent knows the algorithm being used (e.g., RSA or AES), they cannot reverse the encryption process without the specific key.

The integrity of the entire system relies on this key remaining known only to the authorized sender and receiver. If this secret information is leaked, the "Transformation" becomes transparent to the opponent, rendering the security model ineffective.

Model for Network Security

3. The Trusted Third Party:

In large, real-world networks, manually exchanging secret keys between every possible pair of users is logistically impossible and highly insecure

The TTP acts as an intermediary responsible for the secure distribution of keys to the communicating parties

By relying on a central, trusted authority, entities can establish secure channels without having to meet in person to share keys beforehand.

TTP also plays a role in validating digital certificates, ensuring that the entities participating in the communication are who they claim to be, effectively anchoring trust within the network environment.

Principle of Cryptography

Cryptography is the formal scientific discipline of constructing and analyzing mathematical protocols that enable secure communication in the presence of adversaries. It is the core mechanism used to protect information from unauthorized access, modification, or impersonation.

- **Plaintext:** The original, readable data or message before it undergoes the encryption process.
- **Ciphertext:** The scrambled, unreadable output produced after an encryption algorithm has been applied to the plaintext.
- **Encryption:** The process of converting plaintext into ciphertext using an algorithm and a key.
- **Decryption:** The inverse process of converting ciphertext back into the original plaintext, requiring the correct key.
- **Algorithm:** The mathematical formula or logic used to perform the transformation.
- **Key:** A piece of secret information used by the algorithm. The security of the data relies on the secrecy of the key, not the secrecy of the algorithm itself.

Principle of Cryptography

1. Confidentiality

- Confidentiality ensures that sensitive information is disclosed only to authorized individuals or systems.
- It prevents "passive attacks," where an unauthorized party monitors a communication channel to steal data.
- This is achieved through encryption.
- The data (plaintext) is transformed into an unreadable format (ciphertext) using an algorithm and a secret key.

Principle of Cryptography

2. Integrity

- Integrity ensures that the data has not been altered, modified, or corrupted during transit.
- It prevents "active attacks" where an adversary intercepts a message, changes the content (e.g., changing a bank transfer amount from 100 to 10,000), and forwards it to the receiver.
- This is achieved through cryptographic hash functions. A hash function produces a "message digest" a unique digital fingerprint of the data.
- The receiver re-calculates the hash of the received message and compares it to the original hash sent by the sender. If they match, integrity is confirmed.

Principle of Cryptography

3. Authentication

- Authentication is the process of verifying the identity of the user, device, or system.
- This is typically handled through Digital Certificates and Public Key Infrastructure (PKI).
- A Certificate Authority (CA) acts as a trusted third party. They issue a certificate that binds a specific public key to a specific entity (like a website).
- When you connect to a server, it sends its certificate. Your browser verifies the CA's signature on that certificate to confirm the server's identity.

Principle of Cryptography

4. Non-Repudiation

- Non-repudiation provides proof of the origin and integrity of data.
- It ensures that a sender cannot later deny having sent a message or signed a document. This is critical for legal, financial, and contractual digital transactions.
- The sender generates a hash of the document and encrypts that hash using their own Private Key. This encrypted hash is the digital signature.
- The receiver uses the sender's Public Key to decrypt the signature. If it decrypts successfully and the resulting hash matches the document, the receiver has absolute proof that the signature was created by the holder of that specific private key.

Secret Key/Symmetric key Cryptography

Symmetric key cryptography, also known as secret key cryptography, is a method of encryption where the sender and the receiver use the same secret key to both encrypt and decrypt information.

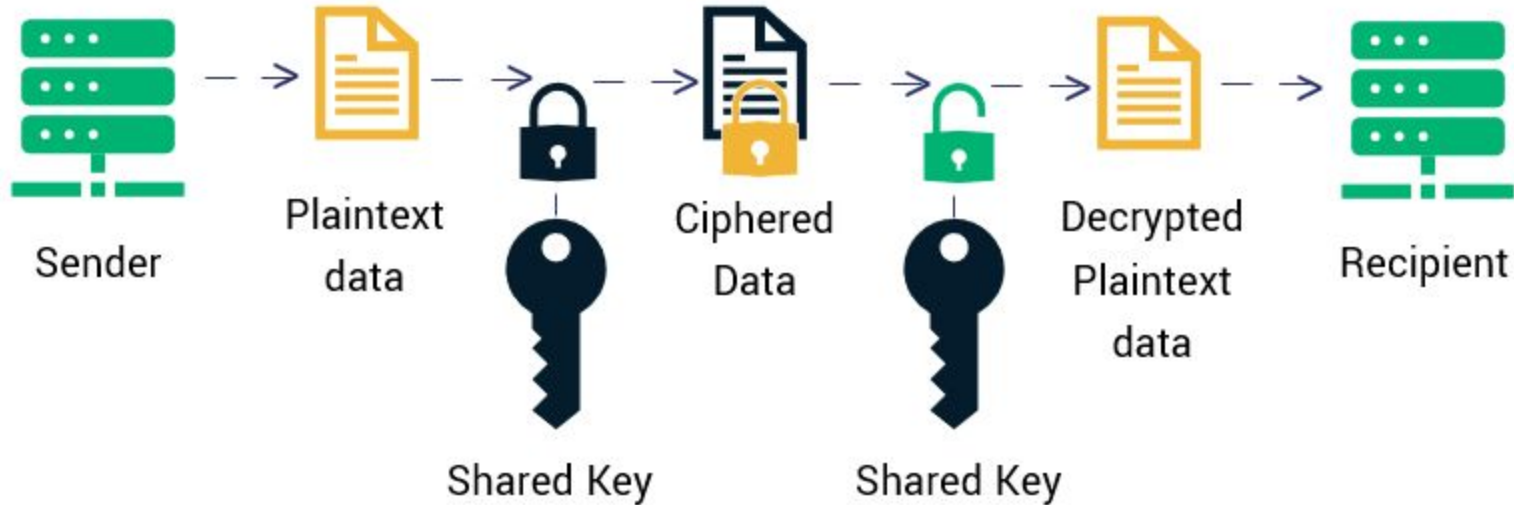
Step 1 (Encryption): The sender takes the Plaintext (original data) and combines it with the Shared Secret Key using a specific mathematical algorithm (the Cipher). This results in Ciphertext (scrambled, unreadable data).

Step 2 (Transmission): The ciphertext is sent over the network. Even if an attacker intercepts the data, they possess only the scrambled noise, not the key, making the content unreadable.

Step 3 (Decryption): The receiver receives the ciphertext and applies the same shared secret key using the inverse algorithm. This recovers the original plaintext.

Secret Key/Symmetric key Cryptography

Symmetric Encryption



Public Key Cryptography

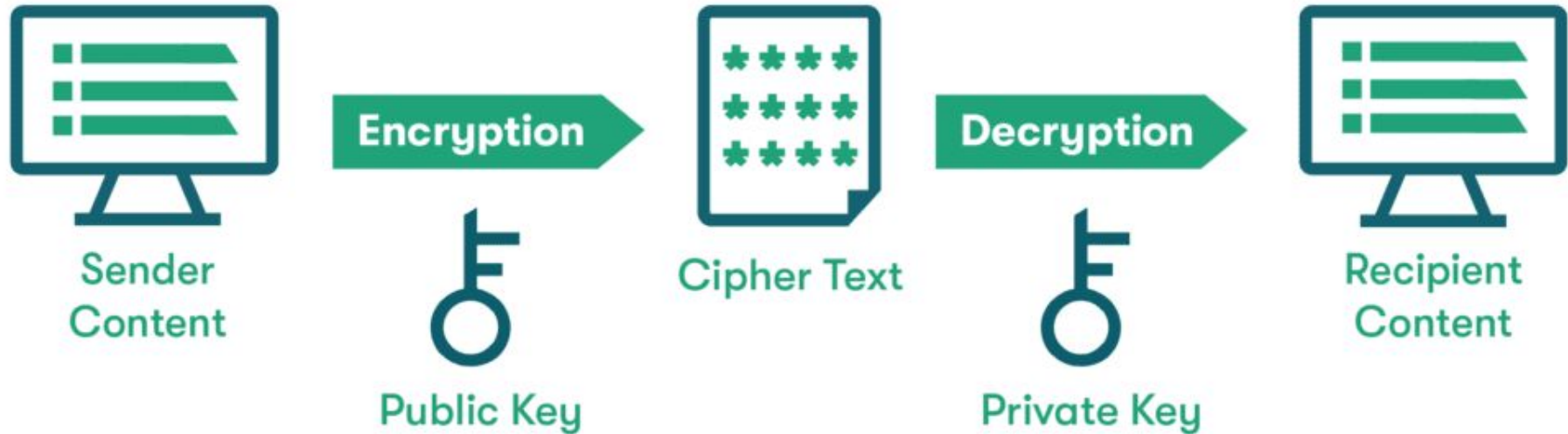
Unlike symmetric systems that rely on a single, shared secret key, Asymmetric Cryptography utilizes a mathematically linked key pair:

The Public Key: This key is designed to be shared openly. It is published on servers, attached to emails, or presented during the initial phase of a network connection. Anyone can use it.

The Private Key: This is the "secret" part of the pair. It must be kept strictly confidential by the owner. It is mathematically impossible (within current computational limits) to derive the Private Key from the Public Key.

If Alice wants to send a secure message to Bob, she encrypts the data using Bob's Public Key. Only Bob, who holds the corresponding Private Key, can decrypt and read the message.

Public Key Cryptography

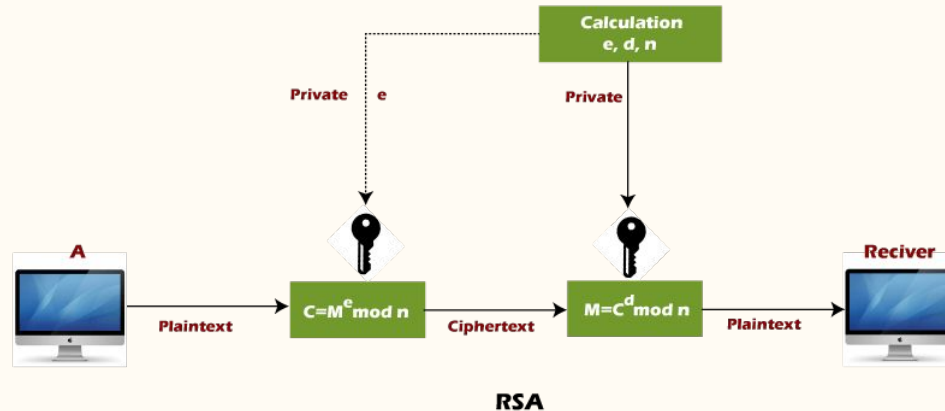


RSA

The RSA (Rivest-Shamir-Adleman) algorithm is the industry-standard for asymmetric (public-key) encryption.

It relies on the mathematical difficulty of factoring the product of two very large prime numbers.

If an attacker knows the product (n), they cannot easily deduce the original prime numbers (p and q), which is the "trapdoor" that makes the encryption secure.



RSA Key Generation

1. **Select Primes:** Choose two distinct, large prime numbers, p and q .
2. **Compute n :** Calculate $n = p \times q$. This n is used as the modulus for both keys.
3. **Compute Totient ($\phi(n)$):** Calculate the Euler's totient function
$$\phi(n) = (p-1) \times (q-1).$$
4. **Choose e (Public Exponent):** Choose an integer e such that $1 < e < \phi(n)$ and e shares no common factors with $\phi(n)$ (they are coprime).
Common practice is to use $e = 65537$.
5. **Compute d (Private Exponent):** Calculate d such that d is the modular multiplicative inverse of e modulo $\phi(n)$.
This means $(d \times e) \bmod \phi(n) = 1$.

Note:

$$d = (1 + k \cdot \phi(n)) / e \text{ where } [k = 0, 1, 2, 3, \dots]$$

$$e = (1 + k \cdot \phi(n)) / d$$

RSA Key Generation

- Choose $p = 3$ and $q = 11$
- Compute $n = p * q = 3 * 11 = 33$
- Compute $\varphi(n) = (p - 1) * (q - 1) = 2 * 10 = 20$
- Choose e such that $1 < e < \varphi(n)$ and e and $\varphi(n)$ are coprime.
Let $e = 7$
- Compute a value for d such that $(d * e) \% \varphi(n) = 1$. One solution is
 $d = 3$ $[(3 * 7) \% 20 = 1]$
- Public key is $(e, n) \Rightarrow (7, 33)$
- Private key is $(d, n) \Rightarrow (3, 33)$
- The encryption of $m = 2$ is $c = 128 \% 33 = 29$ ($M^e \bmod n$)
- The decryption of $c = 29$ is $m = 24389 \% 33 = 2$ ($C^d \bmod n$)

RSA Exmple Question

1. In an RSA cryptosystem, a particular A uses two prime numbers, 13 and 17, to generate the public and private keys. If the public of A is 35. Then the private key of A is ?

Ans: 11

2. A RSA cryptosystem uses two prime numbers 3 and 13 to generate the public key= 3 and the private key = 7. What is the value of cipher text for a plain text?

Ans: 8

3. A RSA cryptosystem uses two prime numbers, 3 and 11, to generate private key = 7. What is the value of ciphertext for a plain text 5 using the RSA public-key encryption algorithm?

Ans: 3

Digital Signature Algorithm

DSA is the mathematical standard used to ensure that a digital document or message is authentic, has not been tampered with, and that the sender cannot deny having sent it.

It is not a scanned image of your handwritten signature. It is a cryptographic mechanism that provides three critical security services:

Authentication: It verifies the identity of the sender. The receiver knows the message definitely came from the holder of the corresponding private key.

Integrity: It guarantees that the message has not been altered in transit. If even a single bit of the data is modified, the signature validation will fail.

Non-Repudiation: It prevents the sender from denying that they signed the document. Because the private key is (theoretically) known only to the owner, they cannot claim, "I didn't send that."

Digital Signature Algorithm Process

Signing:

Step 1 - Hashing: The sender passes the original message through a hash function (like SHA-256) to create a fixed-size "message digest."

Step 2 - Signing: The sender encrypts this digest (not the whole message) using their Private Key.

The Result: This encrypted digest is the Digital Signature. The sender attaches this signature to the original message and sends both to the receiver.

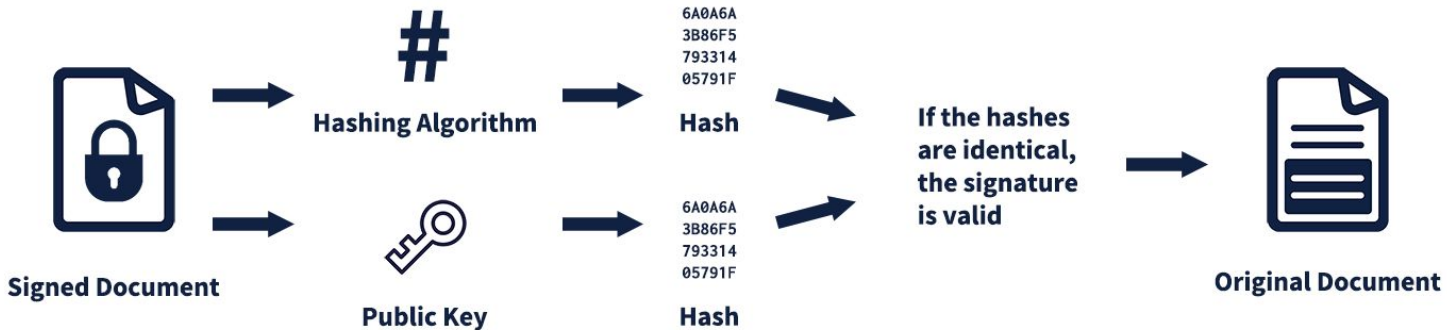
Verification:

Independent Hash: The receiver takes the message they received and calculates the hash using the same algorithm the sender used.

Decryption: The receiver takes the digital signature and decrypts it using the sender's Public Key. This reveals the original hash that the sender created.

Comparison: The receiver compares the hash they calculated in Step 1 with the hash they decrypted in Step 2.

Digital Signature Algorithm



Communication Security: IPSec

IPsec (Internet Protocol Security) is the standard suite of protocols used to secure IP communications.

While standard IP (Internet Protocol) was designed for connectivity, it was never built with security in mind. IPsec functions as a "security wrapper" that ensures the data packets traveling across the public internet are private, authentic, and untampered.

Modes:

- 1. Transport Mode:** Encrypts only the payload of the packet. The original IP header remains visible. Secure communication between two specific servers/hosts. It is faster but reveals the internal IP addresses.
- 2. Tunnel Mode:** Encrypts the entire original IP packet (header + payload) and wraps it inside a new, external IP packet. Used in Site-to-Site VPNs. It hides the internal network topology entirely from the public internet.

Communication Security: IPSec Protocols

ESP (Encapsulating Security Payload):

ESP is the most widely used protocol in the IPsec suite. It provides the full range of modern security services.

Confidentiality: It encrypts the original data payload so that anyone intercepting the packet sees only scrambled, unreadable data.

Integrity: It attaches a cryptographic hash to the packet, which allows the receiver to verify that the data has not been altered or corrupted in transit.

Authentication: It confirms that the packet truly originated from the authorized sender.

Communication Security: IPSec Protocols

AH (Authentication Header)

AH is the older protocol in the IPsec suite. It was designed to provide integrity and authentication.

Integrity and Authentication: Like ESP, it provides a cryptographic signature for every packet, allowing the receiver to verify the sender's identity and detect tampering.

No Encryption: AH does not encrypt the data. The original payload remains visible in plain text. Because modern security demands privacy (encryption) as a baseline requirement, ESP has effectively rendered AH obsolete.

Communication Security: IPsec IKE

IKE(Internet Key Exchange) is the control plane of the IPsec suite. Before any data can be encrypted, the two devices must agree on a set of rules, known as a Security Association (SA). IKE is responsible for this complex handshake.

Phase 1 (The Handshake): The two peers establish a secure, authenticated channel known as the "IKE SA." This channel is itself encrypted to ensure that the negotiation process cannot be intercepted by an attacker. The devices verify each other's identities using digital certificates or pre-shared keys.

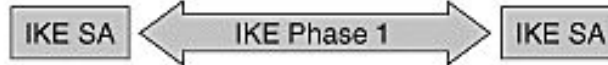
Phase 2 (The Tunneling): Once Phase 1 is secure, the devices use that channel to negotiate the parameters for the actual data tunnel, known as the "IPsec SA." They agree on specific encryption algorithms (like AES) and hashing algorithms (like SHA) that will be used for the bulk data transfer.

Communication Security: IPsec IKE

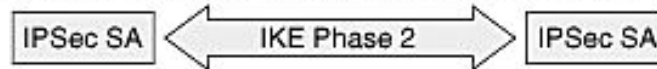
Maintenance: IKE continues to manage the tunnel after it is built. It periodically re-keys the connection, meaning it generates new keys to replace old ones, ensuring that even if a key is compromised, it only remains useful for a limited amount of time.



1. Host A sends interesting traffic to Host B.
2. Routers A and B negotiate an IKE phase one session.



3. Routers A and B negotiate an IKE phase two session.



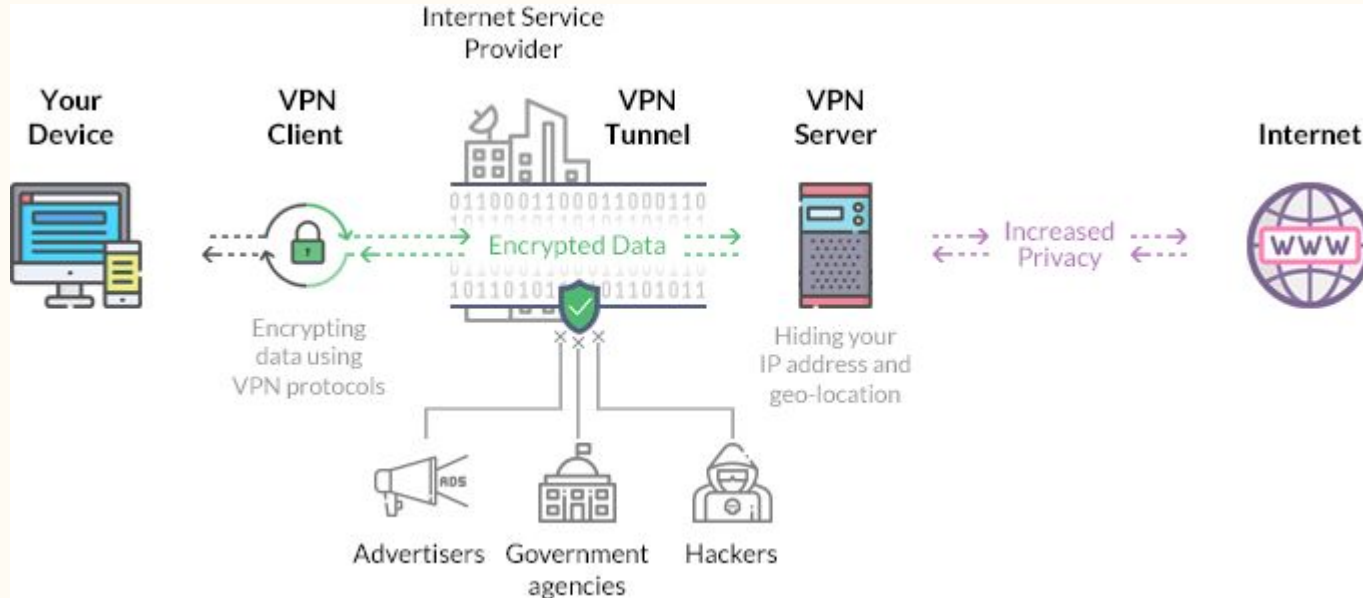
4. Information is exchanged via IPsec tunnel.



5. IPsec tunnel is terminated.

Communication Security: Virtual Private Network (VPN)

A Virtual Private Network (VPN) is a service that creates a secure, encrypted connection between your device and a destination network over the public internet. It effectively allows you to extend a private, internal network across the public, untrusted internet.



Communication Security: VPN Working

The Tunneling Process: When a user initiates a VPN connection, the client software creates a virtual tunnel to the VPN gateway.

Packet Encapsulation: The original data packet (containing the source and destination IP addresses) is treated as the "inner payload." The VPN software wraps this entire packet inside a new "outer" packet.

The Outer Header: The outer packet is addressed to the destination VPN gateway. Because the outer header is readable, routers on the public internet can direct the packet to the VPN gateway, but they remain blind to the contents of the inner packet.

Encryption: The inner payload is encrypted using a symmetric cipher (such as AES). Even if the packet is captured during transit, an attacker would see only the encrypted "envelope" rather than the original data.

Communication Security: VPN Deployment

Remote Access VPN (Client-to-Gateway):

This model connects individual remote users to a central private network. The user runs a VPN client on their device, which initiates an encrypted tunnel to the company's VPN gateway. Once the tunnel is established, the user is assigned an internal IP address and can access internal resources (like file servers or intranets) as if they were sitting inside the physical office.

Site-to-Site VPN (Gateway-to-Gateway):

This model connects entire networks together. Instead of individual software clients, dedicated hardware (like enterprise routers or firewalls) at two different physical locations maintains a permanent, encrypted tunnel. This allows all devices on the "New York" branch network to communicate transparently with the "London" headquarters network.

Communication Security: VPN Protocols

IPsec (Internet Protocol Security): IPsec is an industry-standard suite used primarily for Site-to-Site VPNs. It operates at the Network Layer (Layer 3) and is often integrated into the operating system kernel. While highly secure and efficient, it is complex to configure and can be susceptible to blocking by restrictive firewalls.

OpenVPN: OpenVPN is a versatile, open-source protocol based on the SSL/TLS library. It operates in "user-space," making it highly adaptable and capable of running on virtually any port, including TCP port 443 (the same port used for HTTPS). This makes it excellent at bypassing strict firewalls, though it is generally slower than kernel-level protocols due to "context-switching" overhead.

WireGuard: WireGuard is a modern protocol designed for simplicity and extreme performance. It uses a very small codebase (which makes it easier to audit for security vulnerabilities) and operates within the kernel. It is rapidly becoming the standard for mobile and modern VPN implementations due to its speed and efficiency.

Communication Security: Firewall

A firewall is a fundamental network security device either software or hardware that monitors, filters, and controls incoming and outgoing network traffic based on an organization's previously established security rules.

Working:

At its core, a firewall makes "allow" or "deny" decisions for every packet of data that tries to pass through it. It accomplishes this through Access Control Lists (ACLs), which are sets of instructions that define:

Source/Destination IP addresses: Where is the data from, and where is it going?

Ports: Which application protocol is being used (e.g., Port 80 for Web, Port 22 for SSH)?

Protocol Type: Is it TCP, UDP, or ICMP

Communication Security: Firewall Types

A. Packet Filtering Firewalls (Stateless)

These are the most basic and oldest form of firewalls. They operate at the Network Layer (Layer 3).

They examine each packet in isolation, checking the header information (source IP, destination IP, port) against a set of rules.

Pros: Extremely fast and efficient.

Cons: They have no "memory." They do not know if a packet is part of an existing connection or a new, potentially malicious one. This makes them vulnerable to IP spoofing.

Communication Security: Firewall Types

B. Stateful Inspection Firewalls

Unlike packet filters, these are "state-aware." They operate at both the Network and Transport layers.

They keep track of the state of active connections (e.g., they know a packet is part of an ongoing TCP "handshake").

If a packet arrives that claims to be a response to a request that was never made, the firewall drops it.

Pros: Significantly more secure than stateless filters.

Cons: More resource-intensive as they must maintain a table of all active connections.

Communication Security: Firewall Types

C. Proxy Firewalls (Application-Level Gateways)

These firewalls act as an intermediary between the internal client and the external server.

When you request a webpage, you are actually connecting to the proxy firewall. The firewall evaluates the request, and if it is safe, it makes the request to the real server on your behalf.

Pros: They perform "Deep Packet Inspection" (DPI), meaning they look at the actual content of the request (the payload), not just the header.

Cons: High latency, as every request must be intercepted and re-sent.

Communication Security: Firewall Types

D. Next-Generation Firewalls (NGFW)

This is the current industry standard for modern enterprise security.

An NGFW combines the features of a traditional firewall with advanced capabilities like:

Intrusion Prevention Systems (IPS): Automatically detecting and blocking exploits.

Application Awareness: Identifying what an application is (e.g., blocking Facebook games but allowing Facebook chat).

Encrypted Traffic Inspection: Decrypting SSL/TLS traffic to inspect it for malware before re-encrypting it.

Communication Security: Firewall Deployment Methods

Network-Based Firewalls:

These are dedicated hardware appliances (like a router or a specialized security box) that sit at the edge of the network. They protect the entire internal network.

Host-Based Firewalls:

These are software applications installed on a single computer (e.g., Windows Firewall or iptables in Linux). They protect only the specific device they are running on.

Communication Security: Wireless Security

Wired Network:

- Data travels inside a physical copper or fiber-optic cable.
- To steal data, an attacker needs physical access to the wire or a switch port.
- The network is essentially a "closed" system.

Wireless Network:

- Wi-Fi is a broadcast medium.
- When your router sends data to your phone, it is essentially "shouting" that data into the air.
- Anyone within the radio range of your Access Point (AP) even from a parking lot or an adjacent apartment can "hear" that broadcast.

Communication Security: Wireless Security

Every wireless security protocol needs to handle two distinct phases:

Authentication: The device and the router prove their identities and establish a "Master Key" (often derived from your Wi-Fi password).

Encryption: Every data packet sent after the introduction is scrambled using a specific mathematical algorithm (a cipher) so that an eavesdropper sees only noise.

Communication Security: Wireless Security Protocols

WEP (Wired Equivalent Privacy):

WEP was the first attempt at wireless security, released in 1999. It used a stream cipher called RC4 to encrypt data.

It relied on a static key combined with a 24-bit "Initialization Vector" (IV). The IV was meant to make every packet look different, even if the data was the same.

The IV was too short. On a busy network, the IV would repeat quickly. Because the RC4 algorithm relies on these IVs to stay secure, repeating them allowed attackers to mathematically "reverse" the key.

Communication Security: Wireless Security Protocols

WPA (Wi-Fi Protected Access): The "Wrapper"

When WEP was proven broken, WPA was released as an emergency "patch" that could be installed on older hardware.

It did not change the underlying encryption engine (it still used RC4), but it added a new layer on top called TKIP (Temporal Key Integrity Protocol).

Instead of using one static key like WEP, TKIP generated a new key for every single data packet.

It was effective at stopping simple WEP-style attacks, but because it still used the fundamentally weak RC4 cipher, it was only meant to be a temporary solution until better hardware could be manufactured.

Communication Security: Wireless Security Protocols

WPA2: The AES Standard and the Handshake:

WPA2 (released in 2004) was a massive leap forward. It replaced the fragile RC4 cipher with AES (Advanced Encryption Standard), a block cipher that is the same standard used by the U.S. government for top-secret data.

WPA2 uses AES in a mode called CCMP. It encrypts data in fixed-size blocks, which is mathematically robust and resistant to the kinds of frequency analysis that killed WEP.

While the encryption is strong, the connection process (the 4-Way Handshake) has a logic flaw. When a device connects, it performs a 4-step exchange to prove it has the password without actually sending the password. Attackers can "sniff" these four packets from the air, take them offline, and run a dictionary attack to guess the password.

The End